

Þetta gengur vel. Höldum áfram í "Technical Specification v0.7".

Já — þá förum við í **Technical Specification v0.7 — API Contract & OpenAPI Specification**.

Við höldum sama architecture-principles og í v0.6 og gerum þetta nú nægilega nákvæmt til að hægt sé að nota það sem grunn fyrir bæði frontend og backend implementation.

Technical Specification v0.7

API Contract & OpenAPI Specification

Project: Icelandic Legal Case Management System — ILCMS

Version: 0.7

Status: API Contract Baseline

Date: September 2026

1. Purpose

Technical Specification v0.7 skilgreinir formlegt API contract fyrir ILCMS.

Markmiðið er að API specification sé sameiginlegt contract milli:

- Web frontend
- Backend services
- Mobile/future clients
- External integrations
- Automation
- AI services

API skal vera:

- RESTful
- versioned
- strongly typed
- authorization-aware
- auditable
- idempotent þar sem við á
- OpenAPI compatible.

2. API Design Principles

2.1 Base URL

Production:

`https://<host>/api/v1`

Development:

`http://localhost:8000/api/v1`

API version er hluti af URL:

`/api/v1`

Breaking changes fara í:

`/api/v2`

3. Content Types

Primary request/response format:

`Content-Type: application/json`

Document upload:

`Content-Type: multipart/form-data`

Large document upload má nota presigned object-storage URLs.

4. Authentication

API notar OAuth 2.0 / OpenID Connect access tokens.

`Authorization: Bearer <access_token>`

JWT claims geta meðal annars innihaldið:

```
{
  "sub": "user-id",
  "iss": "https://identity.example",
  "aud": "ilcms-api",
  "exp": 1780000000
}
```

API má ekki treysta eingöngu á claims fyrir case-level authorization.

5. Authorization

Authorization er framkvæmt í backend.

Primary permission model:

RESOURCE : ACTION

Dæmi:

CASE : READ

CASE : CREATE

CASE : UPDATE

CASE : DELETE

DOCUMENT : READ

DOCUMENT : UPLOAD

DOCUMENT : DOWNLOAD

DOCUMENT : DELETE

DOCUMENT : EXPORT

EVIDENCE : READ

EVIDENCE : CREATE

EVIDENCE : UPDATE

FILING : READ

FILING : CREATE

FILING : SUBMIT

AUDIT : READ

CASE : ADMIN

Case ACL og confidentiality restrictions eru síðan metin ofan á permissions.

6. Standard HTTP Status Codes

Statu s	Meaning
200	Successful request
201	Resource created
202	Accepted for asynchronous processing
204	Successful, no response body
400	Invalid request
401	Authentication required/invalid
403	Authorization denied
404	Resource not found

409	Conflict
422	Validation error
429	Rate limit exceeded
500	Internal error
503	Service unavailable

7. Standard Error Model

Öll errors skulu fylgja sama format:

```
{
  "error": {
    "code": "CASE_ACCESS_DENIED",
    "message": "Access denied.",
    "request_id": "01JXXXXXXX"
  }
}
```

`request_id` skal vera notað til að tengja API request við logs og audit events.

8. Validation Error

HTTP 422:

```
{
  "error": {
    "code": "VALIDATION_ERROR",
    "message": "Request validation failed.",
    "request_id": "01JXXXXXXX",
    "details": [
      {
        "field": "title",
        "code": "required"
      }
    ]
  }
}
```

Ekki skal senda database exception eða internal stack trace til client.

9. Pagination

List endpoints nota cursor eða page-based pagination.

MVP:

```
?page=1&page_size=50
```

Maximum:

```
page_size <= 100
```

Response:

```
{
  "items": [],
  "page": 1,
  "page_size": 50,
  "total": 124,
  "pages": 3
}
```

Fyrir mjög stór datasets er cursor pagination preferred í framtíðinni.

10. Sorting

Standard:

```
?sort=created_at
```

Descending:

```
?sort=-created_at
```

Dæmi:

```
GET /cases?sort=-updated_at
```

API skal whitelist-a leyfða sort fields.

11. Filtering

Dæmi:

```
GET /cases?status=OPEN
```

Multiple filters:

```
GET /cases?status=OPEN&priority=HIGH
```

Ekki leyfa arbitrary SQL expressions í query parameters.

12. Request Correlation

Client má senda:

X-Request-ID: <uuid>
Ef það vantar skapar API nýtt ID.

Response skal innihalda:

X-Request-ID: <uuid>

13. Cases API

13.1 Create Case

POST /cases
Permission:

CASE:CREATE
Request:

```
{
  "case_number": "LGM-2026-00123",
  "title": "Example legal matter",
  "description": "Case description",
  "case_type": "CIVIL",
  "priority": "NORMAL",
  "confidentiality": "CONFIDENTIAL",
  "responsible_user_id": "user-123"
}
```

Response:

201 Created

```
{
  "id": "case-uuid",
  "case_number": "LGM-2026-00123",
  "title": "Example legal matter",
  "status": "DRAFT",
  "created_at": "2026-09-01T17:00:00Z"
}
```

Audit:

CASE_CREATED

14. Get Case

GET /cases/{case_id}
Permission:

CASE:READ

Response:

```
{
  "id": "case-uuid",
  "case_number": "LGM-2026-00123",
  "title": "Example legal matter",
  "description": "...",
  "case_type": "CIVIL",
  "status": "OPEN",
  "priority": "NORMAL",
  "confidentiality": "CONFIDENTIAL",
  "responsible_user": {
    "id": "user-123",
    "display_name": "John Doe"
  },
  "created_at": "...",
  "updated_at": "..."
}
```

15. List Cases

GET /cases

Filters:

status
case_type
priority
responsible_user_id
created_from
created_to

Example:

GET /cases?status=OPEN&priority=HIGH

Response:

```
{
  "items": [
    {
      "id": "case-uuid",
      "case_number": "LGM-2026-00123",
      "title": "Example legal matter",
      "status": "OPEN",
      "priority": "HIGH"
    }
  ],
  "page": 1,
}
```

```
    "page_size": 50,  
    "total": 1,  
    "pages": 1  
}
```

Authorization filtering skal eiga sér stað áður en results eru skilað.

16. Update Case

PATCH /cases/{case_id}

Permission:

CASE:UPDATE

Example:

```
{  
  "title": "Updated title",  
  "priority": "HIGH"  
}
```

Response:

200 OK

Audit:

CASE_UPDATED

17. Case State Transition

State changes eiga ekki að vera venjulegt PATCH.

POST /cases/{case_id}/transitions

Request:

```
{  
  "transition": "OPEN"  
}
```

Possible states:

DRAFT

OPEN

INVESTIGATION

LITIGATION

SETTLED

CLOSED

ARCHIVED

Backend validates legal transitions.

Example:

DRAFT → OPEN
OPEN → INVESTIGATION
INVESTIGATION → LITIGATION
LITIGATION → SETTLED
LITIGATION → CLOSED
CLOSED → ARCHIVED

Response:

```
{
  "case_id": "case-uuid",
  "previous_status": "DRAFT",
  "new_status": "OPEN",
  "transitioned_at": "...",
}
```

Audit:

CASE_STATUS_CHANGED

18. Parties API

GET /cases/{case_id}/parties
POST /cases/{case_id}/parties
GET /cases/{case_id}/parties/{party_id}
PATCH /cases/{case_id}/parties/{party_id}
DELETE /cases/{case_id}/parties/{party_id}

Create:

```
{
  "party_type": "PERSON",
  "role": "PLAINTIFF",
  "name": "Example Person",
  "organization": null,
  "external_reference": null
}
```

PII access skal fylgja case authorization.

19. Documents API

19.1 Upload Session

Fyrir stór skjöl:

POST /cases/{case_id}/documents/upload-session

Request:

```
{
  "filename": "contract.pdf",
  "content_type": "application/pdf",
  "size": 1234567
}
```

Response:

```
{
  "upload_id": "upload-uuid",
  "document_id": "document-uuid",
  "upload_url": "...",
  "expires_at": "..."
}
```

Authorization er framkvæmd áður en upload URL er búið til.

20. Complete Upload

Eftir upload:

POST /documents/{document_id}/complete

Response:

202 Accepted

```
{
  "document_id": "document-uuid",
  "status": "PROCESSING",
  "job_id": "job-uuid"
}
```

21. Document Processing State

UPLOADING

↓

QUARANTINED

↓

SCANNING

↓

VALIDATED

↓

PROCESSING

↓

AVAILABLE

Error:

PROCESSING_FAILED

Security failure:

REJECTED

22. Get Document

GET /documents/{document_id}

Response:

```
{
  "id": "document-uuid",
  "case_id": "case-uuid",
  "filename": "contract.pdf",
  "content_type": "application/pdf",
  "size": 1234567,
  "status": "AVAILABLE",
  "sha256": "...",
  "version": 3,
  "confidentiality": "CONFIDENTIAL",
  "created_at": "...",
  "updated_at": "..."
}
```

SHA-256 er integrity metadata.

23. Download Document

POST /documents/{document_id}/download

Permission:

DOCUMENT:DOWNLOAD

Response getur verið:

```
{
  "download_url": "...",
  "expires_at": "..."
}
```

URL skal vera short-lived.

Download skal skapa audit event:

DOCUMENT_DOWNLOADED

24. Document Versions

GET /documents/{document_id}/versions

Response:

```
{
  "items": [
    {
      "version": 1,
      "filename": "contract.pdf",
      "sha256": "...",
      "created_at": "...",
      "created_by": "user-123"
    },
    {
      "version": 2,
      "filename": "contract.pdf",
      "sha256": "...",
      "created_at": "...",
      "created_by": "user-456"
    }
  ]
}
```

Versions eru immutable.

25. Create Document Version

POST /documents/{document_id}/versions

Permission:

DOCUMENT:UPLOAD

Ný útgáfa:

version 1

↓

version 2

↓

version 3

Ekki overwrite-a binary.

26. Evidence API

GET /cases/{case_id}/evidence

POST /cases/{case_id}/evidence

GET /evidence/{evidence_id}

PATCH /evidence/{evidence_id}

Example:

```
{
  "title": "Email correspondence",
  "description": "Relevant correspondence",
  "evidence_type": "DOCUMENT",
  "source": "Email archive",
  "reliability": "HIGH"
}
```

27. Court Filing API

```
GET    /cases/{case_id}/filings
POST   /cases/{case_id}/filings
GET    /filings/{filing_id}
PATCH /filings/{filing_id}
POST   /filings/{filing_id}/submit
Filing state:
```

```
DRAFT
REVIEW
APPROVED
SUBMITTED
ACCEPTED
REJECTED
```

28. Filing Submission

```
POST /filings/{filing_id}/submit
Permission:
```

```
FILING:SUBMIT
Response:
```

```
202 Accepted
{
  "filing_id": "filing-uuid",
  "status": "SUBMITTING",
  "job_id": "job-uuid"
}
```

Submission má vera asynchronous vegna external court integrations.

29. Deadlines API

```
GET    /cases/{case_id}/deadlines
POST   /cases/{case_id}/deadlines
GET    /deadlines/{deadline_id}
PATCH /deadlines/{deadline_id}
DELETE /deadlines/{deadline_id}
```

Example:

```
{
  "title": "Submit response",
  "due_at": "2026-10-15T16:00:00Z",
  "priority": "HIGH",
  "responsible_user_id": "user-123"
}
```

30. Deadline Completion

```
POST /deadlines/{deadline_id}/complete
```

Response:

```
{
  "id": "deadline-uuid",
  "status": "COMPLETED",
  "completed_at": "..."
}
```

Audit:

```
DEADLINE_COMPLETED
```

31. Tasks API

```
GET    /tasks
POST   /cases/{case_id}/tasks
GET    /tasks/{task_id}
PATCH /tasks/{task_id}
POST   /tasks/{task_id}/complete
```

Task states:

```
OPEN
IN_PROGRESS
BLOCKED
COMPLETED
CANCELLED
```

32. Search API

GET /search

Example:

GET /search?q=contract+termination

Filters:

case_id

document_type

created_from

created_to

confidentiality

Response:

```
{
  "items": [
    {
      "type": "document",
      "id": "document-uuid",
      "case_id": "case-uuid",
      "title": "Contract",
      "snippet": "...termination...",
      "score": 0.93
    }
  ]
}
```

Search result skal vera authorization filtered.

33. Audit API

Audit er read-only fyrir venjulega API clients.

GET /cases/{case_id}/audit

Permission:

AUDIT:READ

Response:

```
{
  "items": [
    {
      "id": "audit-uuid",
      "action": "DOCUMENT_DOWNLOADED",
      "user_id": "user-123",
      "document_id": "document-uuid",
      "timestamp": "...",
      "request_id": "..."
    }
  ]
}
```

```
    }  
  ]  
}
```

Audit records má ekki vera editable í API.

34. Approval API

```
GET    /cases/{case_id}/approvals  
POST   /cases/{case_id}/approvals  
POST   /approvals/{approval_id}/approve  
POST   /approvals/{approval_id}/reject  
Approval state:
```

```
PENDING  
APPROVED  
REJECTED  
CANCELLED  
Approval request:
```

```
{  
  "type": "COURT_FILING",  
  "resource_id": "filing-uuid",  
  "required_role": "SENIOR_LAWYER"  
}
```

35. Legal Hold API

```
GET    /cases/{case_id}/legal-holds  
POST   /cases/{case_id}/legal-holds  
POST   /legal-holds/{hold_id}/release  
Legal hold getur komið í veg fyrir:
```

```
document deletion  
case deletion  
retention purge
```

36. Retention API

Venjulegur notandi má ekki stjórna retention policy.

Administrative API:

```
GET    /retention/policies  
POST   /retention/policies
```

PATCH /retention/policies/{policy_id}
Actual deletion skal fara í gegnum background workflow.

37. Notifications API

GET /notifications
POST /notifications/{notification_id}/read
POST /notifications/read-all
Notification:

```
{
  "id": "notification-uuid",
  "type": "DEADLINE_APPROACHING",
  "title": "Deadline approaching",
  "case_id": "case-uuid",
  "read": false,
  "created_at": "..."
```

38. Current User API

GET /me
Response:

```
{
  "id": "user-123",
  "display_name": "John Doe",
  "email": "user@example.com",
  "roles": [
    "LAWYER"
  ],
  "permissions": [
    "CASE:READ",
    "DOCUMENT:READ",
    "DOCUMENT:DOWNLOAD"
  ]
}
```

39. Health API

GET /health/live
GET /health/ready
/health/live má aðeins staðfesta að application process sé alive.

/health/ready má athuga:

PostgreSQL

Message broker

Object storage

Ekki skila credentials eða internal configuration.

40. Asynchronous Jobs API

GET /jobs/{job_id}

Response:

```
{
  "id": "job-uuid",
  "type": "DOCUMENT_OCR",
  "status": "RUNNING",
  "progress": 65,
  "created_at": "...",
  "updated_at": "..."}
}
```

States:

QUEUED

RUNNING

COMPLETED

FAILED

CANCELLED

41. Idempotency

Operations sem geta valdið duplicate side effects skulu styðja:

Idempotency-Key: <unique-key>

Sérstaklega:

POST /cases

POST /documents/.../complete

POST /filings/.../submit

POST /approvals

POST /exports

Dæmi:

Idempotency-Key: 5d9f...

Sama key + sama request skal skila sömu niðurstöðu.

42. Optimistic Concurrency

Resources skulu hafa:

version
eða:

ETag
Dæmi:

If-Match: "version-12"
Ef resource hefur breyst:

409 Conflict

Þetta kemur í veg fyrir að tveir notendur overwrite-i breytingar hvors annars.

43. Bulk Operations

Bulk operations skulu ekki keyra stórar breytingar synchronously.

Dæmi:

POST /documents/bulk-export
Response:

```
202 Accepted
{
  "job_id": "job-uuid",
  "status": "QUEUED"
}
```

44. Export API

POST /cases/{case_id}/export
Request:

```
{
  "include_documents": true,
  "include_evidence": true,
  "include_audit": true,
  "format": "ZIP"
}
```

Export workflow:

REQUEST
↓

AUTHORIZATION

↓

OPTIONAL APPROVAL

↓

QUEUE

↓

GENERATE

↓

HASH

↓

AUDIT

↓

DOWNLOAD

45. AI API

AI endpointar skulu vera aðskildir frá almennum CRUD operations.

```
POST /cases/{case_id}/ai/summarize
```

```
POST /documents/{document_id}/ai/summarize
```

```
POST /cases/{case_id}/ai/timeline
```

```
POST /cases/{case_id}/ai/extract-issues
```

Response:

```
202 Accepted
```

```
{
  "job_id": "job-uuid",
  "status": "QUEUED"
}
```

AI output verður ekki sjálfkrafa vistað sem authoritative legal fact.

46. AI Result

```
GET /ai/results/{result_id}
```

Example:

```
{
  "id": "ai-result-uuid",
  "type": "CASE_SUMMARY",
  "case_id": "case-uuid",
  "status": "COMPLETED",
  "model": "local-model",
  "generated_at": "...",
  "content": "...",
}
```

```
"review_status": "UNREVIEWED"
}
```

Review:

UNREVIEWED

REVIEWED

ACCEPTED

REJECTED

47. Security Requirement for AI

AI endpoints skulu framkvæma:

Authentication

↓

Permission check

↓

Case ACL

↓

Document ACL

↓

Confidentiality check

↓

AI request

AI service má ekki sjálf bypass-a authorization.

48. OpenAPI Tags

OpenAPI specification skal nota tags:

Authentication

Cases

Parties

Documents

Evidence

Filings

Deadlines

Tasks

Search

Approvals

Legal Holds

Retention

Notifications

Audit

Jobs
AI
Administration
Health

49. Example OpenAPI Structure

```
openapi: 3.1.0

info:
  title: ILCMS API
  version: 1.0.0

servers:
  - url: https://api.example.is/api/v1

security:
  - bearerAuth: []

paths:
  /cases:
    get:
      tags:
        - Cases
      summary: List cases

    post:
      tags:
        - Cases
      summary: Create case

  /cases/{case_id}:
    get:
      tags:
        - Cases
      summary: Get case

    patch:
      tags:
        - Cases
      summary: Update case

components:
```

```
securitySchemes:
```

```
  bearerAuth:  
    type: http  
    scheme: bearer  
    bearerFormat: JWT
```

50. OpenAPI Security Scheme

```
components:
```

```
  securitySchemes:
```

```
    bearerAuth:  
      type: http  
      scheme: bearer  
      bearerFormat: JWT
```

Endpoint getur override-að security ef public endpoint verður til.

51. API Naming Rules

Use plural nouns:

```
/cases  
/documents  
/parties  
/deadlines
```

Ekki:

```
/getCases  
/createCase  
/deleteDocument
```

HTTP method skilgreinir operation.

52. No Verb-Based CRUD URLs

Correct:

```
POST /cases
```

Incorrect:

```
POST /createCase
```

Correct:

```
DELETE /documents/{id}
```

Incorrect:

```
POST /deleteDocument
```

Undantekning: explicit domain actions.

Dæmi:

```
POST /cases/{id}/transitions
```

```
POST /filings/{id}/submit
```

```
POST /deadlines/{id}/complete
```

53. API Security Rules

API skal:

- validate all input
- authorize every protected resource
- never trust client-supplied permissions
- never expose internal IDs unnecessarily
- avoid information leakage
- rate-limit sensitive operations
- audit security-sensitive operations
- reject malformed JWTs
- validate token issuer
- validate audience
- validate expiration
- use TLS in production.

54. Sensitive Operations

Aðgerðir sem skulu alltaf audit-aðar:

```
CASE_CREATED
```

```
CASE_DELETED
```

```
CASE_STATUS_CHANGED
```

DOCUMENT_UPLOADED
DOCUMENT_DOWNLOADED
DOCUMENT_EXPORTED
DOCUMENT_DELETED

EVIDENCE_CREATED
EVIDENCE_UPDATED

FILING_SUBMITTED

APPROVAL_CREATED
APPROVAL_APPROVED
APPROVAL_REJECTED

LEGAL_HOLD_CREATED
LEGAL_HOLD_RELEASED

RETENTION_PURGE

AI_REQUESTED
AI_RESULT_ACCEPTED
AI_RESULT_REJECTED

PERMISSION_CHANGED
USER_ROLE_CHANGED

55. API Audit Metadata

Audit event skal helst innihalda:

```
{  
  "event_id": "...",  
  "timestamp": "...",  
  "user_id": "...",  
  "action": "...",  
  "resource_type": "...",  
  "resource_id": "...",  
  "case_id": "...",  
  "request_id": "...",  
  "ip_address": "...",  
  "user_agent": "..."  
}
```

Varast skal að setja document contents eða secrets í audit.

56. API Contract Testing

CI skal sannreyna að implementation samræmist OpenAPI contract.

OpenAPI

↓

Contract tests

↓

FastAPI

Frontend má einnig generate-a TypeScript client frá OpenAPI.

57. Generated Frontend Client

Recommended:

OpenAPI

↓

TypeScript client generation

↓

React application

Þetta minnkar hættuna á mismatch:

Frontend expects:

case_number

Backend returns:

caseNo

58. Backend Implementation Mapping

API	Service
/cases	CaseService
/documents	DocumentService
/evidence	EvidenceService
/filings	FilingService
/deadlines	DeadlineService
/search	SearchService
/approvals	ApprovalService

/audit	AuditService
/ai	AIService
/jobs	JobService

59. API → Database Rule

API layer má ekki keyra SQL beint.

API

↓

Service

↓

Repository

↓

PostgreSQL

Undantekning getur verið sérstök reporting/query layer, en hún skal samt vera controlled.

60. API → Object Storage Rule

API má ekki gefa client direct permanent object-storage access.

Correct:

Authorization

↓

short-lived URL

↓

object storage

61. API → AI Rule

API má ekki senda:

raw unrestricted case database
til AI.

Það sendir:

authorized context

62. Version Compatibility

Frontend og backend skulu styðja sama major API version.

Frontend v1



API v1

Minor additions skulu vera backward compatible.

Breaking changes:

API v2

63. API Documentation

API documentation skal vera sjálfvirk:

/docs

Swagger UI

og:

/redoc

ReDoc.

Production getur lokað eða varið interactive API documentation með authentication.

64. MVP API Priority

Priority 1

Authentication

Cases

Parties

Documents

Document versions

Deadlines

Tasks

Audit

Priority 2

Evidence

Court filings

Approvals

Search

Notifications

Legal holds

Retention

Priority 3

AI
External integrations
E-signature
Advanced exports

65. Definition of Done — v0.7

v0.7 er lokið þegar:

- API versioning defined
- Authentication defined
- Authorization model defined
- Error model defined
- Pagination defined
- Filtering defined
- Sorting defined
- Case API defined
- Party API defined
- Document API defined
- Evidence API defined
- Filing API defined
- Deadline API defined
- Task API defined
- Search API defined
- Approval API defined
- Audit API defined
- Legal Hold API defined
- Retention API defined
- Notification API defined
- Job API defined
- AI API defined

- Idempotency defined
- Concurrency defined
- Export workflow defined
- OpenAPI structure defined
- Security requirements defined
- Contract-testing strategy defined

66. Next Step — Technical Specification v0.8

Næsta útgáfa ætti að fara úr API contract yfir í **actual implementation design**:

Technical Specification v0.8

Backend Implementation & Domain Services

Þar skilgreinum við nákvæmlega:

```
backend/
├── app/
│   ├── api/
│   ├── domain/
│   ├── services/
│   ├── repositories/
│   ├── models/
│   ├── schemas/
│   ├── security/
│   ├── workflows/
│   ├── events/
│   ├── workers/
│   └── infrastructure/
```

og fyrir hvert domain module:

```
Entity
↓
Pydantic schema
↓
Repository
↓
Service
↓
Authorization
↓
```

Audit

↓

Events

↓

API endpoint

Við getum þá einnig byrjað að skilgreina **raunverulegan Python/FastAPI codebase**, þar með talið `pyproject.toml`, SQLAlchemy models, Pydantic schemas, dependency injection, authentication middleware, authorization decorators/dependencies og fyrstu unit/integration tests.

Síðasta skrefið í v0.8 verður að skilgreina nákvæmlega hvernig **fyrsta vertical slice** verður byggð:

Create Case

↓

Get Case

↓

Update Case

↓

Authorization

↓

Audit

↓

PostgreSQL

↓

API test

Petta verður fyrsta virkilega **end-to-end functional slice** kerfisins.

Við erum þar með komin á þann stað að næsta útgáfa getur farið að innihalda **raunverulegan keyranlegan FastAPI/SQLAlchemy grunn**, frekar en aðeins architectural documentation.